

Sydney Garling

CSCI 499 – Spring 2019

Danger with Digital Forensics

Advisor: Dr. Paul West

Danger with Digital Forensics Abstract

Safely deleting sensitive data from non-volatile data storage before refurbishing is a persistent problem as many programs exist to recover information. Furthermore, recent publications like McAfee's report, *The Hidden Data Economy*, provide monetary amounts for certain sensitive information, like estimated prices per payment card number provide with CVV2. This paper determines the possibility of individuals benefiting from the selling and illegal use of information. This research includes the probability and accessibility of recoverable personal and sensitive information from flash drives after individuals dispose of them believing that the information can no longer be retrieved or viewed. Sensitive information includes, but is not limited to, credit cards numbers, phone numbers, addresses, and social security numbers. People like Lillian Ablon know how detrimental things can get if this type of information falls into malicious hands. This study uses 2 flash drive batches purchased from eBay and a flash drive batch from the South Carolina Federal Highway Lost and Found. The flash drives are run through the data recovery tool, Foremost. Foremost is a built-in data recovery tool for the Kali Linux operating system. The tool is straightforward in the sense that the user can point it at an input drive and direct the output to a desired location. The data recovery process yielded a social security, addresses, and phone numbers, among other pieces of information. With the sensitive information, a criminal holds the potential of earning a living from the purchasing of a few flash drive batches and scanning them for files.

I picked this project for a few reasons:

1. I wish to study more in the field it covered. I intend to study digital forensics in graduate school at the University of South Florida and wanted to learn more about it before I attended there. This project barely scratches the surface of what is considered digital forensics and what I will be learning.
2. Not many people are aware of the importance and necessity of securely deleting data as it is extremely easy for cybercriminals to get their hands on our data. This project was to inform the people and raise awareness of this issue in the hopes of increasing the difficulty or even stopping these criminals from obtaining this information.
3. While I love coding and being a computer science major, I wanted to pick a project that tested the bounds of what I knew and by picking this project, I was able to learn more about tools I had never used before.

Main Goal: To raise awareness about how easy cybercriminals can retrieve our data and inform the population about the different ways to securely delete their data.

Sub Goals:

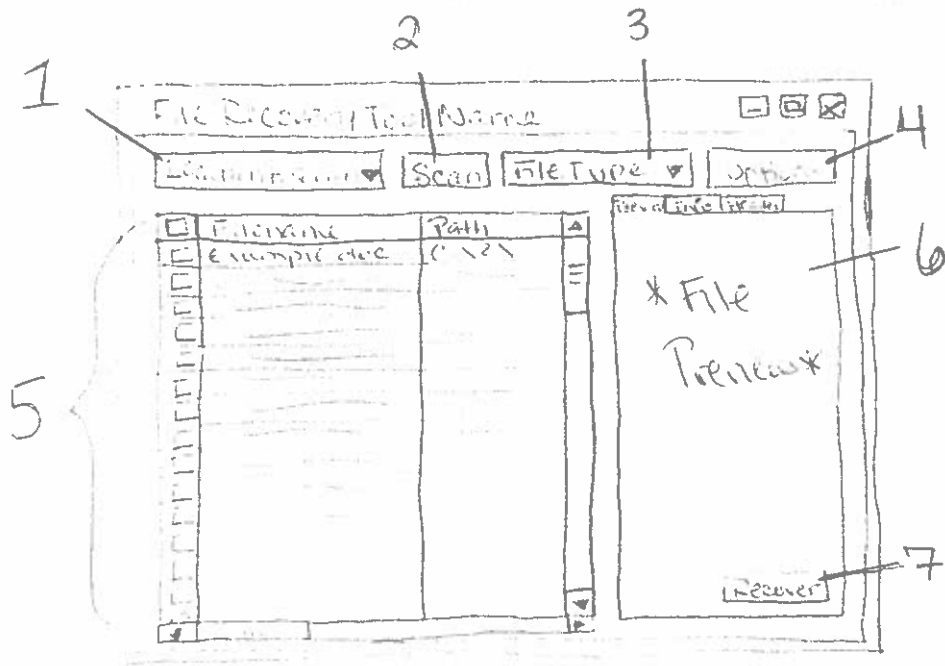
- retrieve sensitive information from obtained flash drives to determine whether or not it is possible a criminal could make a living
- present at NCUR 2019
- get my research published

Tools Used for Project:

1. Kali Linux OS
2. VirtualBox
3. Foremost
4. Flash Drives
5. LibreOffice

Senior Project Design

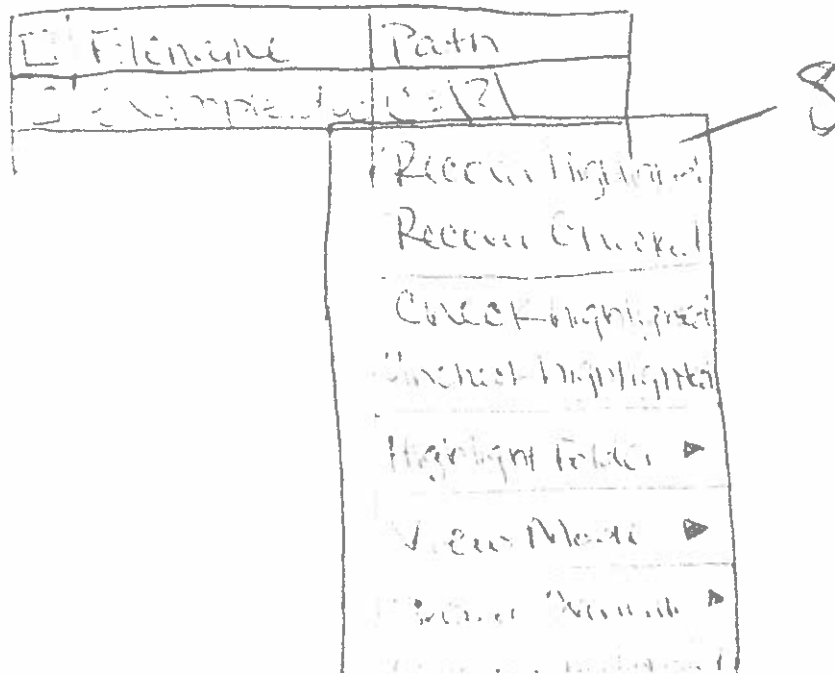
File Recovery Tool Layout



1. This lets you select where you want to scan for files on your computer or storage device.
2. This is the scan button which you click to scan the location you selected.
3. This is where you can specify if you are looking for a certain type of file or not.
4. This Options button allows you to add more detailed options to your scan.
5. This is where a list of the recoverable files appear in the location you scanned with their filename and path.
6. This is where the file you have selected is shown as a preview so you can determine if you want to recover that file or not.

7. This is the button you click when you want to recover files; it will give you the option to recover just what you have checked or just the highlighted file.

Right Clicking Files



8. When you right click a file off the list, this menu appears with similar options so that you can recover files (highlighted/checked), (un)check the highlighted file, highlight the folder the file is contained in, the ability to change the view mode, and to securely overwrite files which means you completely wipe it from the system or storage device.

Student Name: Sydney Garling

Advisor Name: Dr. Paul West

Expected Date of Graduation: May 2019

Description of Project:

This project will be investigating how thoroughly people delete information off of flash drives before selling or giving them away. Along with research, the plan is to see how much information is left on flash drives put up for sale and whether any of it is sensitive enough to be sold for money. The question is whether it is plausible for someone to make a living off of buying flash drives and selling the information they find, based on the information prices on the Dark Web that McAfee found. Thus, a file recovery tool will be downloaded to use on some flash drives as well as some printer/copier hard drives to see what can be uncovered.

Proposed Implementation Language(s):

None

Any software/hardware equipment needed:

- Personal Computer
- Virtual Box with virtual machine set-up
- One of the file recovery tools listed below:
 - Recuva
 - SoftPerfect
 - EaseUS
 - Restoration
 - TOKIWA
 - Active File Recvoery

- Unformat
- Data Recovery Wizard
- Stellar
- DMDE

Motivation and Problem Statement:

This project will shed light on how much more effort people need to put in to cleaning their storage devices as well as keeping their sensitive information safe.

Outline of Future Efforts:

This project will be in the form of a research paper where a discussion of all findings and how much information can be found will occur. Any deliverables will be in the form of lists stating what has been found and what storage devices have been searched.

Schedule:

April 25th, 2018: All hardware pieces will have been collected. The virtual machine will be set-up and the file recovery tool will be installed.

May 9th, 2018: The first batch of flash drives will be searched by this day. Any files recovered will be copied over to a folder on the desktop.

May 23rd, 2018: The second batch of flash drives will be searched by this day. Any files recovered will be copied over to a folder on the desktop.

June 6th, 2018: The final batch of flash drives will be searched by this day. Any files recovered will be copied over to a folder on the desktop.

June 20th, 2018: If recovered, the first printer's storage device will be searched by this day. Any files recovered will be copied over to a folder on the desktop.

July 3rd, 2018: If recovered, the second printer's storage device will be searched by this day. Any files recovered will be copied over to a folder on the desktop.

July 18th, 2018: If recovered, the third printer's storage device will be searched by this day. Any files recovered will be copied over to a folder on the desktop.

August 8th, 2018: All files recovered will be searched by this day and any sensitive information will be noted and the files moved to another folder.

September 19th, 2018: The rough draft of the research paper will be completed. The paper will be submitted for feedback.

November 7th, 2018: The second draft of the paper will be completed. It will be submitted for final feedback.

November 28th, 2018: The final draft of the paper will be turned in for grading.

December 19th, 2018: Create a skeleton for the presentation and prepare questions judges may ask.

January 16th, 2019: Fill in half the presentation and prepare answers for potential questions.

February 13th, 2019: Finish the remainder of the presentation and turn in for feedback.

March 20th, 2018: Finish incorporating feedback into the presentation. Turn in the finalized project.

Outline

I. The Danger Explained

- a. A previous study by McAfee outlines some prices for sensitive information
- b. People assume that by right-clicking and selecting delete their file is gone and no one can access it anymore (False).
- c. Could someone manage to live off of buying and finding flash drives, recovering data from them, and selling any recovered sensitive information on the dark web?
(Main purpose)

II. The set-up process

- a. Obtaining the flash drives
 - i. The first batch was purchased off of eBay from a seller.
 - 1. Batch of 8
 - ii. The second batch was also purchased from eBay, the same seller.
 - 1. Batch of 7
 - iii. The third batch was obtained from my father whom retrieved the drives from the lost and found at Federal Highway.
 - 1. Batch of 11
- b. Setting up the virtual machine
 - i. installing Kali Linux

III. Process of data recovery

- a. labeling and inserting flash drive
- b. running of foremost
- c. organization of data recovered by flash drive

IV. Processing of data

- a. sifting through retrieved files
- b. logging names of files with potentially sensitive information

V. Analyze sensitive information found

- a. price information based on research
- b. calculate the cost vs. profit
- c. include chart from McAfee as well as own

VI. List finding

- a. explain how calculations show whether or not a person could survive by finding and selling sensitive information

VII. Discuss ways users can properly dispose of their files to prevent data recovery

- a. reformatting of flash drives
- b. scrubbing flash drives with tools
- c. Physically destroy

Research Paper

Danger with Digital Forensics

I. The Danger Explained

Digital forensics is like a double-edged sword. On the one hand, it can be used to help us solve crimes and fix security issues. On another hand, it can be used to commit the very crimes we try to stop. In investigations, digital forensics tools are often used to recover erased or damaged data on confiscated devices collected as evidence. What the investigators hope to find is information that can help track the perpetrators or help predict what they will do next.

The other side of this are cybercriminals, and they can use these tools to recover data as well. With the different utilities nowadays, even a technologically-inept person could commit cybercrimes. These criminals are looking for private information about a person that falls under personal, financial, or medical information because “Data is the “oil” of the digital economy”. (McFarland et al, 2015). This kind of people commit these crimes for one reason: “financial gain – they care about making money” (Ablon, 2018). The best way to keep a perpetrator from obtaining your sensitive data is to securely delete it.

Secure deletion is “The act of completely and irrevocably getting rid of data” (Diesburg, et al, 2016). Secure deletion permanently erases a file, which means that if a person gets rid of a device, someone else cannot go and retrieve the data thought to be erased, unbeknownst to the previous owner. Criminals will be unable to recover a prevented victim’s sensitive data and thus, they will be safe. Perpetrators mostly try “targeting the “low-hanging fruit”” (Ablon, 2018), the easiest targets. Even moderate protection will dissuade the majority of attackers and thieves.

II. The Set-Up Process

I selected the Kali Linux operating system for the numerous cybersecurity tools that come pre-installed, including a data recovery tool called Foremost. I decided on using a virtual machine to protect my actual computer in case any of the drives I obtained contained malware.

The flash drives I collected for this project were retrieved from two locations. The first batch was purchased from a seller off of eBay with a total of 8 drives. The second batch was purchased from the same seller on eBay with a total of 7 drives. The third batch was collected by my father whom retrieved them from the lost and found at Federal Highway in Columbia, South Carolina. The third batch contained 11 drives, counting to a total of 26 drives.

III. Process of Data Recovery

As I received the flash drives for my research, they were kept together with the batches they arrived in. Then within the batches, each flash drive was given a letter ID to differentiate them from the others and to help with later organization. You see, most people don't "appropriately protect their data – often with significant ramifications." (McFarland et al, 2015). After the flash drives were assigned identification, I initiated the data recovery process using a tool called Foremost.

Foremost is a rather simple tool really. To begin data recovery, I first needed to ensure the flash drive I wished to recover data from was connected and visible to the virtual machine. From there, I had to identify what the drive was labeled as according to the virtual machine. To achieve this, I used the following command: `sudo fdisk -l`. That command will list out all the devices that are connected to the virtual machine.

Once I identified which disk was mine, I had the location where I needed to point Foremost at. After that, I had to locate or create a location where Foremost could output any recovered

files. From there, I just needed to run the command: `foremost -i <device location> -o <output location>`. Foremost will work on recovering files from the device location you gave and outputting anything it finds into the output location you gave. This process can take as little as a few minutes to days depending on the size of the drive.

The organization of the data after it was recovered was made easy thanks to Foremost. When you run Foremost and point it to output at a specific location, it organizes the data it recovers by the file type. Because of that, I only had to organize the data by which flash drive it was recovered off of using the letter ID and which batch the flash drive was from. Organization is a major necessity as it makes your work easier later on.

IV. Processing of Data

A file is considered and marked as potentially important if it contained, but not limited to, any of the following: personally identifiable information (PII), corporate commercial, corporate confidential, and illicit (Diesburg et al, 2016). The process by which I searched for and identified potentially important files was relatively simple. Essentially, I skimmed through files, looking for information that could identify or hold importance with a person. If I noticed any information that fell along those lines, I made note of the file as potentially important.

As I discovered files that came to be labeled as “potentially important”, I made a separate folder for those files and copied the file over to said folder. I organized these files the same way Foremost did, by the file type. Then I create an Excel spreadsheet where each sheet represented a flash drive batch. Each column was used to represent the flash drive with the same letter ID. Any files that came to be labeled as “potentially important” had their file name listed under their drive’s respective column.

V. Findings and Analysis

When recovering data, there is no telling what will be found. Anything from insignificant data like a paper from school all the way to personal identification information like social security numbers could be retrieved. Generally, recovered data falls into three categories: personal, medical, or financial.

Just like any other economy, the economy of stolen information is affected by the flow of supply and demand. Cybercriminals consider data to be very valuable (McFarland et al, 2015). The prices of data also are affected by certain factors during the attack that retrieved it. Most of the time, there is too much data on the market for sale and the price drops because the demand for data is not high enough to maintain or increase the price. Data that leads to more is considered more valuable because it has the potential of a larger yield. Additionally, the freshest data sells for a higher price as the breach it came from has likely not been discovered yet or a recovery process has not been initiated yet (Ablon, 2018). Most of the data types have dynamic prices that are in constant flux.

One type of data that tends to have a calmer fluctuation is credit card information. Credit card information tends to be sold in larger batches. When a batch is purchased, the hope is that there are at least a few cards that have not been reported yet to potentially exploit money from. Even after the cards are more than likely cancelled, they can still be sold for a small amount.

Payment Card Number With CVV2	United States	United Kingdom	Canada	Australia	European Union
Random	\$5-\$8	\$20-\$25	\$20-\$25	\$21-\$25	\$25-\$30
With Bank ID Number	\$15	\$25	\$25	\$25	\$30
With Date of Birth	\$15	\$30	\$30	\$30	\$35
With Fullinfo	\$30	\$35	\$40	\$40	\$45

Table 1. Estimated per card prices, in US\$, for stolen payment card data (Visa, MasterCard, Amex, Discover).

Source: McAfee Labs.

These are just a few numbers from the research McAfee did about the economy that is controlled by the purchasing and selling of data.

From the 26 flash drives I obtained for this study, the total number of recovered files was 83,791; that is an average of 3223 files per drive. 23% of the flash drives contained potentially sensitive files. 112 of the files recovered contained potentially sensitive information. From these files, I calculated 1,206 names, 1,692 phone numbers, 746 emails, 23 signatures, 33 fax numbers, 137 addresses, 4 pictures with 14 total faces, 2 passports, 1 social security number, 1 driver license, 1 set of building evacuation plans, and 1 set of IT room plans.

The flash drives I collected for this study cost approximately \$100 to gather. To determine whether a cybercriminal could easily make minimum wage or not and essentially live off of selling others information, I analyzed the data I collected from the recovered files to determine the overall profit of what I had found.

With the data I collected, most of the pieces could be sold in batches where they wouldn't be sold for much individually but could bring in a decent amount together. The piece de resistance is the two passports I found. While the one that has expired may not be worth as much, the passport that is still valid is worth between \$1,000 and \$2,000, according to Experian.

Social security number \$1	Online payment services login info \$20-\$200	Credit or debit card \$5-\$110 Web CVV number \$5 Web bank info \$15 Full info* \$30
Driver's license \$20	Loyalty accounts \$20	General non-financial institution logins \$1
Diplomas \$100-\$400	Passports (U.S.) \$1000-\$2000	Subscription services \$1-\$10 Medical records \$1-\$1000**

The passport alone puts me well over the cost of the flash drives and into the green. If we assume that the expired passport would be worth nothing, the current passport could bring in at least \$1,000 and after subtracting the beginning cost, that still leaves me at a \$900 profit.

VI. Proper Ways to Dispose of Data

There are three ways to securely dispose of data from a hard drive. The first is by reformatting the drive. This can generally be done by either right-clicking within a drive and selecting the reformat drive option or by managing the storage of the device and choosing the reformat drive option available. When the drive is reformatted, it overwrites any of the data that may be contained on it.

Another way to dispose of any data on a hard drive is by using a tool or software to scrub the drive. For the drives used in this research, I found a command in Kali that scrubs and overwrites the data on a drive. The command I used was `shred -vfc <device location>`. After running this command on each drive, I ran Foremost over them again to ensure no more data could be collected from it.

A good example of a program to use for secure data deletion is Diesburg's TrueErase. This program "allows a user to mark individual files as *sensitive*, so that they will be deleted securely... In the case of a sensitive folder, all files underneath will be securely deleted" (Diesburg et al, 2016). TrueErase allows you to delete sensitive files individually instead of just a whole drive as well. A practice that should be a constant in everyone's life is that "Once sensitive data is no longer needed, it should be permanently removed from storage" (Diesburg et al, 2016) A user won't have to worry about sensitive information getting out then and don't have to worry about forgetting after some time has passed.

Finally, the last way you can dispose of data permanently from a flash drive is by smashing it. Physically destroying the drive is the safest way to ensure the data cannot be retrieved. Just take it outside and grab a hammer. If you successfully smash it to bits, it will be impossible to recover any data from it, let alone try to piece it back together into a working drive.

VII. Conclusion

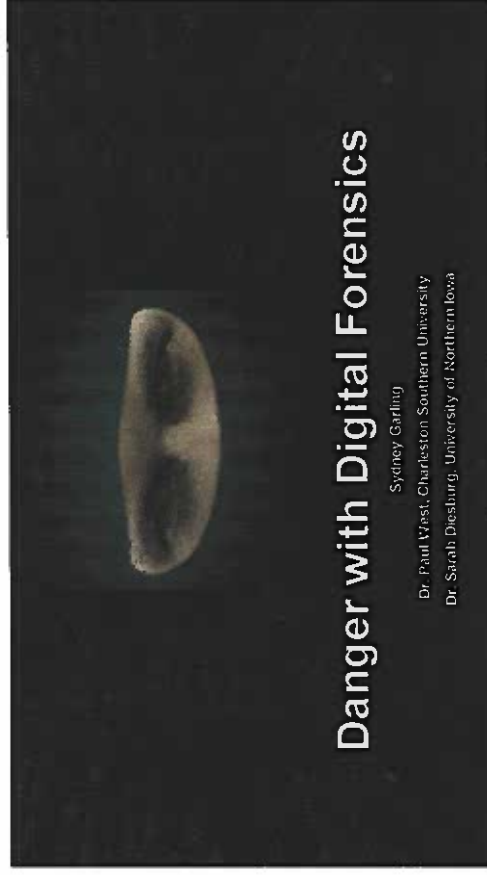
Based on the information I found, a criminal would have easily made over a \$900 profit. Spreading that amount over the span of 2 weeks that it took overall, the criminal would make more than minimum wage. This criminal would be earning a living selling the information of others.

These criminals will always go for the easiest target first. People need to put just minimal effort into protecting themselves and to keep from becoming a target. Users need to start properly permanently erasing their data before disposing of a drive. The first person who is needed to protect your data and you is yourself.

References

- Ablon, L. (2018). Data Thieves: The Motivations of Cyber Threat Actors and Their Use and Monetization of Stolen Data. doi:10.7249/ct490
- Diesburg, S. (2016, December). Ghosts of Deletions Past: New Secure Deletion Challenges and Solutions. Retrieved January 7, 2019.
- Diesburg, S., Feldhaus, C. A., Al Fardan, M., Schlicht, J., & Ploof, N. (2016). Is Your Data Gone? Measuring User Perceptions of Deletion. STAST. Retrieved January 7, 2019.
- Diesburg, S., Meyers, C., Stanovich, M., Wang, A. A., & Kuenning, G. (2016). TrueErase: Leveraging an Auxiliary Data Path for Per-File Secure Deletion. ACM Transactions on Storage, 12(4), 18th ser., 18:1-18:37. Retrieved January 7, 2019.
- McFarland, C., Paget, F., & Samani, R. (2015, December). The Hidden Data Economy Report [PDF]. McAfee, LLC.
- Stack, B. (2019, March 11). Here's How Much Your Personal Information Is Selling for on the Dark Web. Retrieved March 19, 2019, from <https://www.experian.com/blogs/ask-experian/heres-how-much-your-personal-information-is-selling-for-on-the-dark-web/>
- The Black Market Report [PDF]. (2018). Armor, Inc.
- The Economic Impact of Cybercrime—No Slowing Down [PDF]. (2018, February). McAfee, LLC.

Presentation



The Danger Explained

- Digital forensics is a double-edged sword
 - Solve crimes and stop criminals
 - Theft of data and hijacking of computers
- Cybercriminals' goals:
 - Financial gain [Ablon 2018]
 - Theft of data
 - Intrusion/destruction of system
- Secure deletion – "act of completely and irrevocably getting rid of data" [Diesburg et al 2016]



Set-Up

- Obtaining flash drives
 - Lost & Found
 - Ebay
- Installation of Kali
 - VirtualBox



Process of Data Recovery

- Physically labeling drives
- Drive identification command: `sudo fdisk -l`
- Foremost
 - Data recovery
 - Command: `foremost -i <device location> -o <output location>`
- Organizing all recovered data by drive
 - Further organization by file type



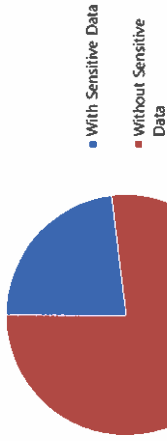
Processing of Data

- Sensitive information: [Diesburg et al 2016]
 - Personally Identifiable Information (full names, addresses, SSNs, ...)
 - Corporate Commercial (advertising, product manuals, ...)
 - Corporate Confidential (customer/employee PII, trade secrets, ...)
 - Illicit
- Sift through files
- Copy files with sensitive information
 - Placed in separate folder
- Record file names for future reference



Findings

Flash Drives



Findings

Data Type	Count
Full Name	1,206
Phone Number	1,692
Email	746
Address	137
Fax Number	33
Passport	2
SSN	1



Analysis

- Data is "oil" [McFarland et al 2015]
- Fresher data better
- PII prices
 - Slack 2019
 - "The Black Market Report" 2018
- Amount from data recovered: \$1000-\$1500
- Cost of project: \$100
- Total amount: \$900-\$1400 profit

Data Type	Price Range
PII Profile (full name, address, phone number, email, SSN, etc.)	\$40-\$200
Passport	\$1000-\$2000

How to properly erase data

- Reformatting drives
- Use drive scrubbing software
 - TrueErase [Diesburg et al 2016]
 - Linux command: `shred -vzf --n 5 <device location>`
- Hammer (Physically)



Conclusion

- Don't know the future use of your drive
- Properly erasing your data is better
- Destroying drive is SAFEST

Challenges

- Searching for sensitive information personally
- Discovery of unsavory files
- Potential risk from drives



What I Learned

- Obtain a write blocker
- Easy for cybercriminals to make money from us
- Difference in data prices

The Future

- Publication of research
- Same project, larger scale
- Creation of digital forensics tool

References

- Ablon, L. (2018). Data Thieves: The Motivations of Cyber Threat Actors and Their Use and Monetization of Stolen Data. doi:10.7249/c490
- Diesburg, S. (2016, December). Ghosts of Deletions Past: New Secure Deletion Challenges and Solutions. Retrieved January 7, 2019.
- Diesburg, S., Feidhaus, C. A., Al Fardan, M., Schlicht, J., & Ploof, N. (2016). Is Your Data Gone? Measuring User Perceptions of Deletion. STAST. Retrieved January 7, 2019.
- Diesburg, S., Meyers, C., Stanovich, M., Wang, A. A., & Kuenning, G. (2016). TrueErase: Leveraging an Auxiliary Data Path for Per-File Secure Deletion. ACM Transactions on Storage, 12(4), 18th ser., 18:1-18:37. Retrieved January 7, 2019.
- McFarland, C., Paget, F., & Samant, R. (2015, December). The Hidden Data Economy Report [PDF]. McAfee, LLC.
- Stack, B. (2019, March 11). Here's How Much Your Personal Information Is Selling for on the Dark Web. Retrieved March 19, 2019, from <https://www.experian.com/blogs/ask-expertian/heres-how-much-your-personal-information-is-selling-for-on-the-dark-web/>
- The Black Market Report [PDF]. (2018). Amnor, Inc.
- The Economic Impact of Cybercrime—No Slowing Down [PDF]. (2018, February). McAfee, LLC.

Acknowledgements

- This research was made possible thanks to Dr. Paul West and Dr. Sarah Diesburg

Questions?

References

Data Thieves:

The Motivations of Cyber Threat Actors and Their Use and Monetization of Stolen Data

Testimony of Lillian Ablon¹
The RAND Corporation²

Before the Committee on Financial Services
Subcommittee on Terrorism and Illicit Finance
United States House of Representatives

March 15, 2018

Good afternoon, Chairman Pearce, Ranking Member Perlmutter, and distinguished members of the subcommittee. Thank you for the invitation to testify at this important hearing, “After the Breach: the Monetization and Illicit Use of Stolen Data.”

Cybersecurity is a constant and growing challenge. Although software is gradually becoming more secure and developers are creating novel approaches to cybersecurity, attackers are becoming more adept and better equipped.³ And as the world embraces more digital and hyperconnected components, the paths become more numerous for attackers to gain access to our most sensitive information.

Data breaches have become commonplace in the United States. In 2017, more than 1,000 data breaches exposed over a billion records of sensitive data.⁴ From banking to retail, health care to entertainment, and even government, no sector is immune. Some of that information has been monetized by threat actors in flourishing underground markets. These cyber black markets offer the computer-hacking tools and services to carry out cybercrime attacks and sell the by-products stolen in those attacks: credit cards, personal data, and intellectual property. In other

¹ The opinions and conclusions expressed in this testimony are the author’s alone and should not be interpreted as representing those of the RAND Corporation or any of the sponsors of its research.

² The RAND Corporation is a research organization that develops solutions to public policy challenges to help make communities throughout the world safer and more secure, healthier and more prosperous. RAND is nonprofit, nonpartisan, and committed to the public interest.

³ Martin C. Libicki, Lillian Ablon, and Tim Webb, *Defender’s Dilemma: Charting a Course Toward Cybersecurity*, Santa Monica, Calif.: RAND Corporation, RR-1024-JNI, 2015 (http://www.rand.org/pubs/research_reports/RR1024.html).

⁴ Identity Theft Resource Center, *2017 Annual Data Breach Year-End Review*, idtheftcenter.org, no date (<https://www.idtheftcenter.org/2017-data-breaches>).

commit a terrorist act.⁸ The movies and media portray what cyberterrorism could be: terrorists crafting digital attacks to take down traffic lights, make trains stop on a dime, and water pipes burst. But to date, no such dramatic events have occurred.

Hacktivists

Hacktivists are typically motivated by a cause—political, economic, or social: from embarrassing celebrities, to highlighting human rights, to waking up a corporation to its vulnerabilities, to going after groups whose ideologies they do not agree with.⁹

Hacktivists may steal and disseminate sensitive, proprietary, or, sometimes, classified data in the name of free speech. Other times, they aim to deny access to a particular service or website by conducting a distributed denial-of-service (DDoS) attack, essentially denying legitimate access by flooding a website with more traffic than it can handle, causing the site to crash.¹⁰

State-Sponsored Actors

State-sponsored actors receive direction, funding, or technical assistance from a nation-state to advance that nation's particular interests. State-sponsored actors have stolen and exfiltrated intellectual property, sensitive personally identifying information (PII), and money to fund or further espionage and exploitation causes. In rare cases, these data appear for sale on underground black markets. Instead, these data are usually kept by the actors for their own purposes. Although the data taken from data breaches might not always appear on underground markets, what *can* appear are the tools and guides for how to take advantage of the vulnerabilities that allowed access to the vulnerable systems in the first place. As an example, a researcher published the flaw that was used to penetrate Equifax, and within 24 hours the information was published to hacking websites and included in hacking toolkits.¹¹ Note, however, that there has not been official attribution of who conducted the intrusion into Equifax.

⁸ Maura Conway, "Reality Bytes: Cyberterrorism and Terrorist 'Use' of the Internet," *First Monday*, November 4, 2002 (<http://firstmonday.org/ojs/index.php/fm/article/view/1001/922>); and Maura Conway, "Cyberterrorism: Hype and Reality," in Leigh Armistead, ed., *Information Warfare: Separating Hype from Reality*, Washington, D.C.: Potomac Books, 2007, pp. 73–93.

⁹ As a few examples, see Paolo Passeri, "List of Hacked Celebrities Who Had (Nude) Photos Leaked," Hackmageddon, August 7, 2012 (<http://www.hackmageddon.com/2012/08/07/list-of-hacked-celebrities-who-had-nude-photos-leaked/>); Lillian Ablon, "Hackerazzi: How Naked Celebrities Might Make the Cloud Safer," *The RAND Blog*, September 8, 2014 (<https://www.rand.org/blog/2014/09/hackerazzi-how-naked-celebrities-might-make-the-cloud.html>); "HBGary Federal Hacked by Anonymous," *Krebs on Security*, February 7, 2011 (<https://krebsonsecurity.com/2011/02/hbgary-federal-hacked-by-anonymous/>); Paula Cohen, "Anonymous Hackers' Group Declares War on ISIS," *CBS News*, November 16, 2015 (<https://www.cbsnews.com/news/anonymous-hackers-declare-war-on-isis/>); "Anonymous Hacks Pro-ISIS Twitter Accounts, Fills Them with Gay Pride," *CBS News*, June 15, 2016 (<https://www.cbsnews.com/news/anonymous-hacks-pro-isis-twitter-accounts-fills-them-with-gay-pride/>).

¹⁰ An example is Operation Payback, which targeted websites of large corporations to shut them down temporarily.

¹¹ Michael Riley, Jordan Roberston, and Anita Sharpe, "The Equifax Hack Has the Hallmarks of State-Sponsored Pros," *Bloomberg*, September 29, 2017 (<https://www.bloomberg.com/news/features/2017-09-29/the-equifax-hack-has-all-the-hallmarks-of-state-sponsored-pros>).

cases, the attackers keep the data for their own espionage purposes or use stolen funds to facilitate future operations.

To get an understanding of what the attackers are doing with the stolen data, and how they are monetizing the data, we need to understand who they are and what motivates them.

Attackers, or *cyber threat actors*, can be grouped by their set of goals, motivation, and capabilities. Four groups of note are *cyberterrorists*, *hacktivists*, *state-sponsored actors*, and *cybercriminals*.⁵ It is important to understand the full environment of threat actors, so I will briefly review these four, but I will focus my testimony largely on state-sponsored actors and cybercriminals, as they are of greatest concern to businesses and the government and merit the most note for this hearing.

Today I will give a brief overview of these four types of cyber threat actors, followed by a discussion of the landscape of the black markets for cybercriminal tools and stolen data, and then finish with some of the ways that state-sponsored actors and cybercriminals use and monetize the stolen data.

Different Cyber Threat Actors Have Different Motivations

Cyberterrorists

Cyberterrorism unites two significant modern concerns: attacks via technology in cyberspace and traditional terrorism. While there is no single or globally accepted definition of *cyberterrorism*, in theory, it consists of a politically motivated extremist group or nonstate actor using cyber techniques to intimidate, coerce, or influence an audience; force a political change; or cause fear or physical harm.⁶

To date, there have been no publicly reported cases of terrorists using the internet to carry out cyberattacks; what has been done that has been attributed to cyberterrorism is more akin to hacktivism. Many terrorists, or nonstate actors, do employ cyber to further their goals. They use the internet in many ways: for information gathering, e.g., learn how to build a bomb; to recruit, meet, and connect with like-minded individuals; and to spread propaganda.⁷ But just “being” in cyberspace does not make a terrorist a cyberterrorist. Cyberspace must be used somehow to

⁵ Robinson and colleagues have documented other categories, such as script kiddies, cyber researchers, and internal actors. Neil Robinson, Luke Gribbon, Veronika Horvath, and Kate Cox, *Cyber-Security Threat Characterization: A Rapid Comparative Analysis*, Santa Monica, Calif.: RAND Corporation, 2013 (https://www.rand.org/pubs/research_reports/RR235.html).

⁶ B. Hoffman, *Inside Terrorism*, New York: Columbia University Press, 2006; R. Ahmad and Z. Yunos, “A Dynamic Cyber Terrorism Framework,” *International Journal of Computer Science and Information Security*, Vol. 10, No. 2012, pp. 149–158.

⁷ Robert S. Mueller III, “Combating Threats in the Cyber World: Outsmarting Terrorists, Hackers, and Spies,” prepared remarks at RSA Cyber Security Conference, San Francisco, Calif., March 1, 2012 (<http://www.fbi.gov/news/speeches/combating-threats-in-the-cyber-world-outsmarting-terrorists-hackers-and-spies>); and Ines, von Behr, Anais Reding, Charlie Edwards, and Luke Gribbon, *Radicalisation in the Digital Era: The Use of the Internet in 15 Cases of Terrorism and Extremism*, Santa Monica, Calif.: RAND Corporation, 2013 (https://www.rand.org/pubs/research_reports/RR453.html).

In a few cases, state-sponsored actors have conducted cyberattacks—which deny, degrade, disrupt, or destroy computing systems—to send a political message. An example of this is the 2014 attack on Sony Pictures Entertainment, where North Korea wanted to advance its political agenda and, in part, to stop the release of the movie *The Interview*.¹²

Rather than viewing what they do as breaking laws, state-sponsored actors maintain that they are acting in accordance with their own laws, and most have accepted that cyberespionage is a legitimate state activity. Deterrence—diplomatic, financial, and economic consequences—is thought by some to play a role in preventing these types of attacks from happening or escalating.¹³

Cybercriminals

1. **Cybercriminals are motivated by financial gain—they care about making money.¹⁴ They want access to our personal, financial, or health data—in order to monetize them on underground black markets. For the retail sector in particular, the stolen data from these hacks appeared within days on black market sites.**

These markets are dispersed, diverse, and segmented—rapidly growing, constantly changing, and innovating to keep pace with consumer trends and prevent law enforcement and security vendors from understanding them. They come in many forms. Some are dedicated to one product or a specialized service. Others offer a range of goods and services for a full life cycle of an attack—from the tools needed to exploit a system, all the way through to the cyberlaundering of the stolen goods. These markets are easy for almost anyone to get involved in—at least at the most basic levels.

2. **Cybercriminals operate behind anonymous and peer-to-peer networks (such as Tor and OpenBazaar, respectively) and use encryption technologies and digital currencies (such as Bitcoin) to hide their communications and transactions.**

Table 1 gives a summary of the various cyber threat actors, their main motivations, and use of stolen data.

¹² FBI, “Update on Sony Investigation,” press release, December 19, 2014 (<https://www.fbi.gov/news/pressrel/press-releases/update-on-sony-investigation>).

¹³ Martin C. Libicki, *It Takes More Than Offensive Capability to Have an Effective Cyberdeterrence Posture*, Santa Monica, Calif.: RAND Corporation, CT-465, 2017 (<https://www.rand.org/pubs/testimonies/CT465.html>).

¹⁴ To be sure, there may be some sense of “nobility” of, for example, Russian actors victimizing Americans.

Table 1. Characteristics, Techniques, and Targets of Cyber Threat Actors

Cyber Threat Actors	Description	Motivator	Technique	Types of Targets	Use of Stolen Data
Cyberterrorists (theoretical)	Extremist groups or nonstate actors using cyber techniques to intimidate, coerce, or influence an audience; force a political change; cause fear or physical harm	Gain support for and deter opposition to a cause; carry out dictates of an ideology	Cause kinetic damage: destroy or disrupt critical infrastructure or systems; loss of life	Determined by actors' ideology	Disrupt critical infrastructure via cyberattack; Change prescription or allergy information; switch or delete medical record; further a campaign on a particular target
Hacktivists	Bring awareness to a cause (political, economic, social); exercise free speech (e.g., "lulz")	Ideological activism; disruption of services or access	Steal and leak sensitive, proprietary, or classified information; conduct DDoS on websites or services	No one type of target	Gather personal information of a specific target; publicize a breach to highlight how vulnerable a particular organization is
State-sponsored actors	Receive direction, funding, or technical assistance from nation-states; highly sophisticated and often use the most-sophisticated methods (e.g., zero-day vulnerabilities); targeted and persistent	Advance interests of their nation-state; further political agenda	Conduct intelligence, surveillance, reconnaissance, espionage; employ watering-hole attacks; exfiltrate data (e.g., intellectual property); degrade or destroy technical components; conduct targeted attacks	Other nation-states, defense contractors, technology sector, and critical infrastructure; (rare) banks or cryptocurrency wallets	Build profiles of possible targets for follow-on targeting, exploitation, or espionage campaigns; use personal, financial, or medical information as leverage to gain other types of intelligence
Cybercriminals	Access personal, financial, or health data to monetize it	Financial gain; power	Use crimeware (e.g., exploit kits, "script-kiddy" tools); rely on already known vulnerabilities; phishing, and spearphishing; smash-and-grab	Data repositories (e.g., banks, retail companies, health care) that can be monetized; cryptocurrency wallets	Use credentials (username/password combinations) and harvest contact lists for phishing attacks; exploit password reuse; conduct identity theft, tax, or medical fraud

↳ Process of Data Recovery

The Challenge of Attribution

4. Attribution after a data breach is difficult. Often there is not enough digital evidence left behind to identify the attackers or their country of origin. That said, there are cases where various commercial security firms and threat analysis groups involved in the aftermath of a breach have found similarities in the malware used in various attacks. In particular, similar malware was used in the 2014 cyberattack on Sony Pictures Entertainment and the 2015–2016 SWIFT data breach (i.e., from North Korea). And many note the strong possibility that the malware for the data breaches of the Office of Personnel Management (OPM), Anthem, and United Airlines originate from the same place (China).¹⁵

There Is Overlap Between These Various Cyber Threat Actors

Although there are distinctions and differences in motivation between each of the cyber threat actors, there is some degree of fluidity between the groups. In many cases, the same tools and techniques are used by different groups, sometimes because those are the only tools available, and other times because that helps with plausible deniability and shifting the blame to a different group. In some countries, state-sponsored actors may work with “citizen hackers” or their country’s cybercriminal elements to carry out an attack.¹⁶

Table 2 provides some more detail about the overlap between the various cyber threat actors.

The Hackers’ Bazaar: How Stolen Information Gets Monetized

- X Turning to the cybercrime black markets, I will outline four aspects: *people, products, places* for communicating and conducting business transactions, and *prices*.¹⁷

¹⁵ SANS Institute InfoSec Reading Room, *United Airlines May 2015 Data Breach: Suggested Near, Mid and Long-Term Mitigating Actions Using the 20 Critical Security Controls*, November 2015 (<https://www.sans.org/reading-room/whitepapers/breaches/united-airlines-2015-data-breach-suggested-near-mid-long-term-mitigating-actions-th-36452>); Threatconnect Intelligence Research Team, (2015, February 27). The Anthem Hack: All Roads Lead to China,” February 27, 2015 (<http://www.threatconnect.com/the-anthem-hack-all-roads-lead-to-china/>).

¹⁶ The attack on Yahoo! is an example of this.

¹⁷ Most of the language and analysis in this section are drawn from Lillian Ablon, Martin C. Libicki, and Andrea A. Golay. *Markets for Cybercrime Tools and Stolen Data: Hackers’ Bazaar*, Santa Monica, Calif.: RAND Corporation, 2014 (https://www.rand.org/pubs/research_reports/RR610.html).

Table 2. Overlap Between the Various Cyber Threat Actors

	Hacktivists	State-Sponsored	Cyberterrorists
Cybercriminals	May use some of the same "script-kiddy" tools for things like DDoS May have some of the same targets Can be difficult to tell them apart	Cybercriminals often have close ties (perhaps funding) to nation-states For sophisticated cybercriminals, often the groups are confused with each other, especially by the media Most of the time, they do not want attribution, though some criminal groups have taken credit for state-sponsored actions	Cybercriminals do not want recognition or attribution Cyberterrorists do typically want attribution
Hacktivists		"Citizen hackers" may have hacktivists connected with state-sponsored actors Some hacktivist groups take credit for state-sponsored actions	May in fact be the same thing: "one man's terrorist is another man's freedom fighter" Both typically want attribution Often use similar low-level attacks (e.g., website defacements, taking over Twitter accounts)
State-Sponsored			May have same goals (e.g., to intimidate, coerce, or influence an audience or force a political change)—but one is in political power and the other is not

People: Who Participates In Cybercrime Markets?

5. Participants in cybercrime black markets come from all over the world, range across all skill levels, and occupy different roles depending on their technical abilities and reputation.

Within these markets, there are often hierarchies and specialized roles: *administrators* sit at the top, followed by *subject-matter experts*, who have sophisticated knowledge of particular areas (e.g., exploit-kit creators, data traffickers, cryptanalysts, those who vet). Next are *intermediaries*, *brokers*, and *vendors* and then the *general membership*.

At the bottom of the hierarchy is where the market meets the consumer. 6. This is where *mules* and virtual money mule services come into play—the final level of participation in the market. Mules use multiple methods to turn the stolen credit card or ecommerce accounts into usable money—for example, by completing wire transfers or shipping goods overseas bought with

6 cont.

stolen funds. Mules can be witting participants (well-informed and organized operations) or unwitting (naïve individuals duped into involvement).¹⁸

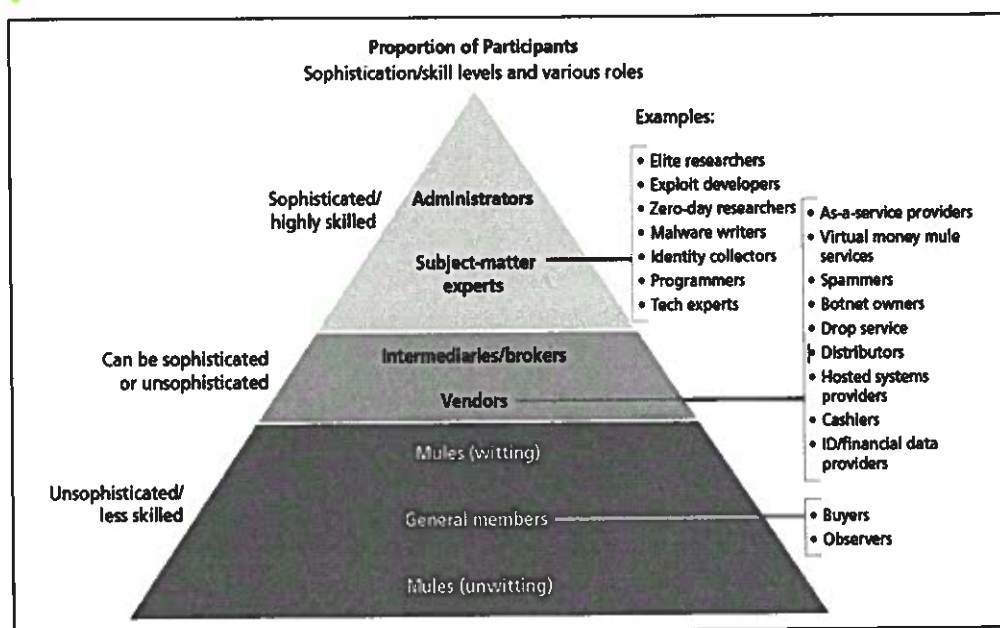
7.

The number of participants in these black markets has increased as barriers to entry diminish. Barriers today to enter and participate in these markets are negligible—essentially all that is needed is an internet connection and a device. This is due to the greater proliferation of websites, forums, and chat channels where goods can be bought and sold. The greater availability of as-a-service models, point-and-click tools, and easy-to-find online tutorials makes it easier for technical novices to use what these markets offer or to just hire someone to carry out an attack for them. An increase in the number of tutorials, manuals, YouTube videos, and Google guides for “how to use exploit kit X” or “where to buy credit cards” also facilitates entry into the lower tiers of these markets, especially for those who wish to be buyers.

Figure 1 depicts the different participant levels in the underground market, proportionally. It also shows the sophistication and technical skill levels and gives examples of various roles.

8. *

Figure 1. Different Levels of Participants in the Cyber Black Markets



SOURCE: Ablon, Libicki, and Golay, 2014.

9.

Surprisingly, these markets are highly reliable—reputation matters a great deal, and, for the most part, products and participants are what they say they are and do what they say they do.

¹⁸ Examples include some “work from home” scams where unwitting people are recruited to purchase goods (using the, unbeknownst to them, stolen credit cards) and then ship them overseas.

9 cont

Reputation entails either having credentials and a good reputation with others or proving oneself (for example, getting good reviews on sales).

Because contracts in black markets cannot be legally enforced, the markets are constantly plagued by *rippers*, who do not provide the goods or services they advertise and are an exception to the high reliability of the markets. Rippers tend to get reported and then quickly removed by administrators (by, for example, suspending their accounts). Although they can easily access new channels under new names, it takes time to reestablish a reputation, which inhibits cheating.

Products: What Is For Sale?

10. Cybercrime markets offer a diverse slate of products, including both goods (hacking tools, digital assets) and services (hacking-as-a-service, digital asset handling, fake-identity creation) for all phases of the full cybercrime life cycle—from initial hack all the way through to monetizing the stolen data.

Examples include tools to help gain initial access onto a target (exploit kits), along with the payloads (malware) and the parts and features of those payloads, services to help scale or deliver a payload, support products to ensure that infrastructure is set up correctly or to provide cryptanalytic services, and considerations for how to manage the stolen goods. As-a-service offerings (setting up botnets or conducting ransomware attacks) are on the rise.

The product slate keeps evolving with the technology. Whatever is new or novel for the traditional consumer—mobile devices, cloud computing, social media platforms—offers new entries for attack and will thus elicit a counterpart exploit on the black market.

Table 3 describes the main categories of products available.

Table 3. Goods and Services on the Black Market

Category	Definition	Examples
Initial access tools	Enable a user to perform arbitrary operations on a machine to then deliver payloads; can automate the exploitation of client-side vulnerabilities	• Exploit kit (hosted or as-a-service) • Zero-day vulnerabilities (and weaponized exploits) • Point of sale (POS) skimmers
Payload parts and features	Goods or services that create, package, or enhance payloads to gain a foothold into a system	• Packers^a • Crypters^b • Binders^c • Obfuscation or evasion
Payloads	Impart malicious behavior, including destruction, denial, degradation, deception, disruption, or data exfiltration	• Bots or botnets for sale • Malware (including that focused on targeting cryptocurrency wallets)
Enabling services	Assist in finding targets or driving targets to a desired destination to use an initial access tool or payload; attack vectors and scaling methods	• Spam services • Pay-per-install and affiliates • Phishing and spearphishing services • Services to drive or find traffic • Fake website design and development
Full services (as-a-service)	Package together initial access tools, payloads, and payload parts and features to conduct attacks on a customer's behalf; can provide full attack life cycle	• Hackers for hire • Botnets for rent • Doxing • DDoS as a service (including DDoS against cryptocurrencies) • Ransomware as a service
Enabling and operations support products	Ensure that initial access tools and hacking services (enabling or full service) work as needed, are set up correctly, and can overcome "speed bumps" or obstacles	• Infrastructure (e.g., leasing services, VPN services, bulletproof hosting, compromised sites and hosts) • Cryptanalytic services (e.g., password cracking, password hash cracking) • CAPTCHA breaking
Digital assets	Items obtained from the target or victim (i.e., the hacked or stolen information)	• Credit card information • Account information (e.g., e-commerce, social media, banking) • Email login and passwords • Online payment service accounts • Credentials • PII/protected health information (PHI)
Digital asset commerce and cyberlaundering	Facilitate turning digital assets into cash	• Mule services • Counterfeit goods and services (e.g., fake documents, IDs, currency) • Card cloners, fake ATMs • Credit card processor services

SOURCE: Ablon, Libicki, and Golay, 2014.

^a The "outer shell" of some malware—e.g., Trojan horses—hides the malware and makes detection and analysis by antivirus software more difficult. Packers can also employ antidebugging, antiemulation, anti-VM techniques, and code obfuscation.

^b Crypters are software that can encrypt executable (.exe) files. Crypters can be used to encrypt viruses, remote access Trojans, keyloggers, spyware, etc. to make them undetectable from antivirus systems.

^c Binders are software used to bind or combine two or more files into one file under one name and extension. They are used for the evasion of anti-virus systems.

Places: How Do These Markets Communicate and Conduct Transactions?

Communications and transactions take place through a variety of channels that span multiple tiers. Channels can include online stores, bulletin board–style web forums, email, or instant messaging platforms (allowing for private one-on-one communications or open chat rooms). Some are easy to find, and others are by invitation only and only accessible after having gone through an extensive vetting process. The highest-access tiers are usually hidden in websites on the dark web, which offer anonymizing and secure features.¹⁹

Transactions can cut across multiple channels and access tiers. An advertisement might be posted on a forum openly available and easily accessed, with actual transactions taking place behind encrypted VPNs, private messaging, locked-down social media accounts (e.g., private Twitter accounts), a shared email (to exchange content through draft messages), or a private server spun up on Tor for just one transaction. As digital goods, payment systems, techniques, tools, and malware continue to evolve, forums with “how to” sections remain popular.

In recent years, there has been more gravitation toward methods of communicating and conducting business transactions that offer anonymity or make it harder for law enforcement to find. Tor—the onion router—is a service one can use to access websites on the dark web and is a way to browse the internet semi-anonymously, essentially masking the location where one is coming from. As law enforcement succeeds in finding and taking down cybercriminal sites, such as AlphaBay and Hansa (two popular dark web marketplaces), there has been more of a move toward decentralized peer-to-peer networks (such as OpenBazaar), where individual users connect with each other, making it difficult for outsiders, such as law enforcement, to track.

Prices: How Much Does Everything Cost?

12. Prices can range widely, depending on hardness of attack, freshness of data, sophistication of malware, or whether something is as-a-service or do-it-yourself.

Easily exchanged goods—such as PII, account credentials, and financial data—are prey to the normal microeconomic fluctuations of supply and demand. Often, there is too much of a product available to sell at normal prices. By contrast, stolen-to-order, nonfungible goods—such as new technology designs, details on R&D activities, mergers and acquisitions, and other sorts of intellectual property—can command a very high price, provided that the right buyer exists.

The yield of a product influences its price. For example, a stolen Twitter account costs more to purchase than a stolen credit card because the former’s account credentials potentially have a greater yield: the username/password combination could unlock access to other accounts, as well as give access to the victim’s contact list in order to carry out follow-on spam or phishing attacks. Immediately after a large breach, batches of credit cards get released in the markets: freshly acquired credit cards command a higher price—as there is greater possibility for the credit cards to still be active. Over time, prices fall because the market becomes flooded with more and more batches—leveling off as the data become stale or if there has been significant time since the last breach. High or no-limit cards (e.g., the American Express Black card) or

¹⁹ A darknet or dark web is an anonymous or semianonymous private network that uses encryption and proxies to obfuscate who is communicating with whom. An example is the onion router (Tor).

12 cont.

cards with chip and PIN are more valuable and can command a higher price: While a U.S. “chip and signature” card might start off for \$15 a number after a breach, a European “chip and pin” card will go for closer to \$120—the higher price point stemming from these types of cards being more secure, often resulting in a higher credit limit. Over time, as banks and users discover the theft and shut down the cards, a card may be discounted to \$12 a number, and then drop further to \$10 a number. Eventually, the credit cards may go on clearance, and one can purchase a “grab bag” of 100 credit card numbers for \$700. The thought here is that, even if only two of those credit card numbers are still open for fraud, one can purchase and then illegally sell electronics, yielding a profit of more than the \$700.

Access to botnets and DDoS capabilities are cheaper because there are so many more options (same for exploit kits).

Although prices, in general, range widely (e.g., hacking into accounts can be anywhere from \$16 to \$325-plus, depending on the account type),²⁰ similar products tend to go for similar amounts. Medical records can be worth up to \$50 per record. Brand-name recognition also plays a role. Services can involve leasing servers, finding traffic, creating a personalized payload (or “cleaning” or obfuscating an already existing payload to avoid antivirus signatures), and setting up infrastructure.

Table 4 summarizes stolen credit card prices and markets.

13.



Table 4. Credit Card Prices Based on Market Circumstance

Card Price (per card)	Market Circumstance
\$120	Freshly acquired (EU card)
\$15	Freshly acquired (U.S. card)
\$10–\$12	Flooded
\$0.75–\$7	Clearance (“stale” data)
SOURCE: Updated from Ablon, Libicki, and Golay, 2014.	

14.

Although transactions can be completed with nondigital currency (e.g., Western Union, cash, PayPal), black market sites have moved toward accepting digital cryptocurrencies, given the appeal of anonymity and other security characteristics. Bitcoin is currently a popular choice, although with the volatility of the cryptocurrency markets, an increase in theft of digital currency wallets, and some notable takedowns by law enforcement of Bitcoin exchanges, it is by no means the only choice. Other, more reasonably priced digital currencies, such as like Ethereum, have become more popular. Further, the possibility that such countries as Russia and China will limit uses of Bitcoin has caused those doing transactions in that virtual currency to find ways to

²⁰ Max Goncharov, *Russian Underground 101*, Cupertino, Calif.: Trend Micro Incorporated, 2012 (<https://www.trendmicro.de/cloud-content/us/pdfs/security-intelligence/white-papers/wp-russian-underground-101.pdf>); Dell Technologies, *Securworks 2017 State of Cybercrime*, February 13, 2018 (<https://www.delltechnologies.com/en-us/perspectives/secureworks-2017-state-of-cybercrime-executive-summary/>); Dell Secureworks, *Underground Hacker Markets: Annual Report—April 2016*, April 2016 (http://online.wsj.com/public/resources/documents/secureworks_hacker_annualreport.pdf).

- X move those funds into other financial system or digital currencies to get their money out and usable. The uses of WebMoney and Perfect Money, online payment settlement systems, remain popular, although because they are not anonymous, users may send their digital currency through a “tumbler” or “washer” to virtually launder the wallet through several different accounts, making the funds difficult to trace.

Making The Stolen Goods Useful: How Data Get Used or Monetized by Cyber Threat Actors

15. The cybercrime black markets can be more profitable than traditional markets for illicit goods: The links to end users are more direct, and worldwide distribution, being electronic, is a relatively trivial task. This is because a majority of players, goods, and services are online-based and can be accessed, harnessed, or controlled remotely, instantaneously. “Shipping” digital goods may only require an email or download at worst—or a username and password to a locked site at best. This enables lower costs and possibly greater profitability.

Cybercriminals are always looking for exotic ways to use or monetize stolen data in ways that law enforcement and security vendors are not looking for or have not yet figured out. That said, because the main motivation of cybercriminals is to make money as quickly as possible,

16. data, which require several steps before they can be monetized, are not as valuable as that which can be monetized quickly. As such, medical records and PHI, credit report information, and extraordinarily sensitive PII are likely more valuable to state-sponsored actors, who might use this information to build profiles to target for exploitation or espionage campaigns, as leverage to gain other types of information, or to help incubate innovative new strategies for using big data against an adversarial country.

In what follows, I describe various categories of stolen data and how each can be monetized or used by cybercriminals or state-sponsored actors. While I note examples of data breaches, unless explicitly stated, I do not intend to imply attribution of a particular cyber threat actor or imply that the data from those breaches have appeared on cybercrime markets for monetization. Instead, my intent is to provide real-world examples of data breaches involving the particular types of data and illustrate what might be done with those data.

17. *Financial information*, such as credit card data and bank account numbers, can get monetized by withdrawing cash, purchasing gift cards for resale, or harnessing a “money mule” (witting or unwitting) to make fraudulent orders to purchase goods, such as expensive electronics, which can then be sold on other black markets.

18. *Credentials*, such as usernames, passwords, account login information, and email addresses, enable an attacker to get access to the victim’s contact list for further spam or phishing campaigns. The actor might also take advantage of password reuse and try to access a variety of banking and ecommerce sites. With access to business email addresses, an attacker can pose as a legitimate employee in the business and request a seemingly legitimate wire transfer, whose funds end up in the account of a money mule, who may then forward on the money or withdraw it and send it to the attacker through different means.

19. The breaches of Target (2013) and Home Depot (2014) are examples of data breaches where attackers collected credit and debit card numbers, as well as account information and email addresses (110 million from Target and 56 million from Home Depot).²¹ The 2013 breach of Yahoo! compromised the accounts of between 500 million and 3 billion users.²² And the 2014 data breach of JP Morgan Chase, where names, addresses, phone numbers, and email addresses of the holders of 76 million households and 7 million small business accounts were taken, was the largest theft of customer data from an American financial institution at the time.²³

20. *Medical records and PHI*, such as the information accessed from Community Health Systems in 2014²⁴ or Anthem in 2015,²⁵ may be used for medical fraud—for example, filling out prescriptions in the victim's name—or combined with other PII to create a more detailed, comprehensive profile.

21. *Financial reports on publicly traded companies*, such as those accessed during the 2016 data breach of the Securities and Exchange Commission's EDGAR database, could provide the attackers information to make illegal trades.²⁶

22. *Credit report information*, such as addresses, dates of birth, social security numbers, driver's license information, and other PII can be combined, creating a comprehensive profile of a victim to create a custom dictionary of possible passwords that can be used to attempt to crack a victim's bank or financial account or for identity theft—posing as the victim to open up new lines of credit or to add new authorized users to existing credit lines. In the 2017 data breach of Equifax, approximately 149 million users had this kind of information taken.²⁷

23. *Extraordinarily sensitive PII*, akin to the kind of information taken from OPM in 2014,²⁸ can facilitate those building comprehensive profiles of victims.²⁹ Cybercriminals might use this information in the same way they use credit report information.

²¹ Target, "Target Confirms Unauthorized Access to Payment Card Data in U.S. Stores," December 19, 2013 (<https://corporate.target.com/press/releases/2013/12/target-confirms-unauthorized-access-to-payment-car>); Home Depot, "The Home Depot Report Findings in Payment Data Breach Investigation," November 6, 2014 (<http://ir.homedepot.com/news-releases/2014/11-06-2014-014517315>)

²² Yahoo! Help, "Yahoo 2013 Account Security Update FAQs," webpage, no date (<https://help.yahoo.com/kb/account/SLN28451.html>).

²³ United States Securities and Exchange Commission, "Form 8-K: JPMorgan Chase & Co.," Shareholder.com, October 2, 2014 (<http://investor.shareholder.com/jpmorganchase/secfiling.cfm?filingID=1193125-14-362173>).

²⁴ Anthem, "2015 Cyber Attack Settlement Agreement Reached," (<http://www.chs.net/media-notice/>).

²⁵ "Anthem Cyber Attack Class Action Settlement Agreement," Anthemfacts.com, no date (<https://www.anthemfacts.com/cyber-attack>); "Anthem Data Breach: Frequently Asked Questions," Databreach-settlement.com, no date (<http://www.databreach-settlement.com/Home/FAQ>).

²⁶ Jay Clayton, "Statement on Cybersecurity," Sec.gov, September 20, 2017 (<https://www.sec.gov/news/public-statement/statement-clayton-2017-09-20>).

²⁷ Equifax, "2017 Cybersecurity Incident and Important Consumer Information," website, Equifaxsecurity2017.com, no date (<https://www.equifaxsecurity2017.com>).

²⁸ OPM, "Cybersecurity Resource Center," webpage, no date (<https://www.opm.gov/cybersecurity/cybersecurity-incidents/>).

²⁹ Data taken from OPM include up to 21.5 million records of Social Security numbers, passport numbers, birthdates, birthplaces, and multiple modes of contact information; details about victims' residential, employment,

Aggregation from Different Data Breaches Can Build a Strong Targeting Profile

Aggregating data from multiple breaches makes the potential for harm much greater. For example, combining credit report information, health care information, and travel information of a person helps to build a comprehensive profile and ideas of how to exploit this person. In this way, if the same actor carried out the hacks on OPM, Anthem, and United Airlines, they would have information on some of the most sensitive personal and health information, which, combined with travel information, can give a fairly comprehensive picture of a potential target, along with locations of frequently traveled places in order to “bump” into them.

And, in some cases, competing groups are all looking for the same data: State-sponsored actors might use credit report information to help build a dossier on a potential counterintelligence target, understanding their weaknesses and vulnerabilities, whereas cybercriminals would use the same information to create the custom dictionary for password guessing.

What Can Be Done?

24.

Each type of cyber threat actor brings its own concerns. With cybercriminals, systems do not need to be completely secure: As long as there are easier and cheaper targets nearby, your safety is much higher. That said, the most sophisticated and determined threat actor will get through no matter what—in this case, security is more about making it expensive for an attacker (in terms of resources, money, time, research, and so on). By adopting certain core technologies, organizations can prevent cybercriminals from targeting the “low-hanging fruit” and instead turn to others with more-lax controls. Cybersecurity solutions that make it harder for threat actors to successfully breach an organization include regular patching and updating systems, employing multifactor authentication, encrypting data (in transit and at rest), and implementing regular security awareness training for people to be more aware of the individual threat and the need to protect themselves.

Recent congressional hearings on Equifax and other data breaches have been useful, highlighting several issues, including potential measures for how to improve response in the wake of a breach. One policy measure would require the extension of identity theft and credit monitoring services for victims to ten years, keeping the requirement for private companies the same as what Congress required of the U.S. government (extended from three years) in the wake of the OPM data breach. From a consumer protection perspective, this makes a lot of sense, given the permanent, unchangeable personal information that was compromised. Other solutions raised included requiring notification following a breach of security of a system containing personal information and amending the Fair Credit Reporting Act to provide access to free credit freezes for all consumers. Although the data from these particular breaches (Equifax and OPM) may not appear on black markets, breach notifications could apply to retailers and other organizations where the data stolen often do appear on black markets. The faster consumers are

25

travel, educational, criminal, financial, addiction, and mental health history; detailed information on spouses, cohabitants, other family members, and foreign contacts; and as many as 5.6 million fingerprint records.

25 cont.

aware of compromises, the lower the prices fetched for this information on the black market, which could disincentive the thefts. Free credit freezes could make it harder for criminals to monetize the information.

While not a cybersecurity panacea, information sharing and international cooperation between the public and private sectors can help.³⁰ State and local law enforcement would benefit from knowing about these markets. Communications between law enforcement, banks, and commercial sectors (health care, retail, entertainment) could help to track down nefarious actors. Although digital currency exchanges are a weak link in attributing a cybercriminal to stolen money, they are often housed overseas. Getting international cooperation is key for law enforcement to successfully pursue the attackers.

Finally, cybercrime markets are highly reliable. Finding ways of tarnishing the reputations of the markets, by wasting a criminal's time or making an exploit tool purchased on the black market ineffective, can help to prevent the loss of information and cut the value chain early in the attack cycle. Solutions might include spreading misinformation or injecting false products into the markets to breed distrust among the actors and increase the number and quality of arrests.

Thank you for the opportunity to testify, and I look forward to your questions.

³⁰ Martin C. Libicki, *Sharing Information About Threats Is Not a Cybersecurity Panacea*, Santa Monica, Calif.: RAND Corporation, CT-425, 2015 (<https://www.rand.org/pubs/testimonies/CT425.html>).

Is Your Data Gone? Measuring User Perceptions of Deletion

S. Diesburg
University of Northern Iowa
311 ITTC
USA
sarah.diesburg@uni.edu

C. A. Feldhaus
University of Northern Iowa
325 WRT
USA
adam.feldhaus@uni.edu

M. Al Fardan
University of Northern Iowa
305 ITTC
USA
alfardm@uni.edu

J. Schlicht
University of Northern Iowa
305 ITTC
USA
schlijaa@uni.edu

N. Ploof
University of Northern Iowa
305 ITTC
USA
ploofn@uni.edu

ABSTRACT

1. Previous studies have shown that many users do not use effective data deletion techniques upon sale or surrender of storage devices. A logical assumption is that many users are still confused concerning proper sanitization techniques of devices upon surrender. This paper strives to measure this assumption through a buyback study with a survey component. We recorded participants' thoughts and beliefs concerning deletion, as well as general demographic information, in relation to actual deletion effectiveness on USB thumb drives. Thumb drives were chosen for this study due to their relative low cost, ease of use, and ubiquity. In addition, we also bought used thumb drives from eBay and Amazon Marketplace to use as a comparison to the wider world.

We found that there is no statistically significant difference between buyback and market drives in terms of deletion methods nor presence of sensitive data, and thus our study may be predictive of the perceptions of the market sellers. In our combined data sets, we found over 60% of the drives tested still had recoverable sensitive data, and in the buyback group, we found no correlation between users' perceived versus actual effectiveness of deletion methods. Our results suggest the security community may need to take a different approach to increase the usability, availability, and/or necessity of strong deletion methods.

CCS CONCEPTS

• Security and privacy~Usability in security and privacy • Hardware~External storage

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from Permissions@acm.org.

STAST '16, December 05 2016, Los Angeles, CA, USA
© 2016 ACM. ISBN 978-1-4503-4826-3 16/12 \$15.00
DOI: <http://dx.doi.org/10.1145/3046055.3046057>

KEYWORDS

Human factors, secure deletion, thumb drives, NAND flash

ACM Reference format:

S. Diesburg, C. A. Feldhaus, M. Al Fardan, J. Schlicht, and N. Ploof. 2016. SIG Proceedings Paper in word Format. In *Proceedings of ACM Socio-Technical Aspects in Security and Trust Workshop, Los Angeles, California USA, December 2016 (STAST '2016)*, 13 pages.
DOI: 10.1145/3046055.3046057

1 INTRODUCTION

2. Personal electronic privacy is increasingly important, and one area of privacy is in the deletion of data on personal storage devices. It is common knowledge in the file systems and storage community that files merely deleted with the delete key or emptied from the trash/recycle bin may be recovered with forensics tools or “undelete” programs. This is because typical file deletion only updates the file’s metadata (e.g., pointers to the data) for bookkeeping purposes, while often leaving the file data intact. Even formatting the file system with the default “quick” option does not ensure secure deletion. For example, the MSDOS format command has been shown to only overwrite 0.1% of the data [12]. As a consequence, data thought to have been erased may still be retrieved from a wide array of decommissioned storage devices, including hard drives [12, 45] and USB storage devices like thumb drives [23].

3. In addition, the growing availability of mobile computing and storage devices encourages sensitive data to be portably stored. For example, an employee can carry a laptop that holds thousands of Social Security numbers, medical histories, and other confidential information. According to a Cisco survey [6], almost one in four employees said they carry corporate data on portable storage devices outside the office.

One answer to this problem is secure deletion, which is concerned with rendering a file’s removed content and metadata (e.g., information such as a file’s name, size, and owner)

irrecoverable. Guidelines have been posted on proper sanitization of electronic storage [15, 16, 29, 43], and many business and organizational policies require data to be erased from storage once it is no longer needed [17, 14, 38, 11]. Also, many free secure deletion tools have been made widely available to the public.

With all of the guidelines, information, and tools available concerning the sanitization of storage media, many users still do not use effective secure deletion methods to sanitize storage devices. A popular assumption is that many users are confused or unknowledgeable concerning best practices of sanitization of data from their devices upon surrender. Is this really true? To test this assumption, we ask the following questions in this study:

1. What types of potentially-sensitive data do users fail to delete?
2. In which way do users choose to surrender their device? In other words, do they attempt weak, strong, or no deletion methods prior to surrender?
3. Does any correlation exist between users' perceived versus actual effectiveness of deletion? In other words, do users that use weak deletion methods understand that the method is weak, and vice-versa?
4. Do the answers to the above questions differ across general demographics information, such as age and gender?

We chose to conduct our study using USB thumb drives. Even though their raw numbers may be declining due to more readily-available cloud storage, they are still very common due to their ease of use, ease of sharing, and situations where transferring data over a network may be impractical or too slow. Used thumb drives are also readily sold over the Internet at a comparably cheaper cost than hard drives or solid state storage drives. Even though they may store sensitive data, thumb drives are often treated in a less-secure manner than hard drives (e.g., left on a desk in plain sight, allowed to travel outside organizations with the user, or lost [1, 30]). In short, thumb drives are an often overlooked, yet fruitful, target for those interested in identify theft [31] or gaining other sensitive information such as trade secrets.

To measure users' perceived effectiveness of deletion, as well as other beliefs concerning deletion, we conducted a buyback study in which we asked participants to trade an old thumb drive for a new 8GB USB 3.0 thumb drive while answering questions to a short survey. Our study collected and analyzed 140 participant drives. No identifying information about the participants was recorded, and the study was approved through our institution through IRB #14-0240. In addition, we did not answer participants' questions about if or how they should delete data from their drives.

To supplement our study, we also purchased 120 used thumb drives from eBay and Amazon Marketplace (henceforth called market drives). We purchased drives from a wide variety of sellers in hopes of increasing drive diversity.

In both groups of thumb drives, we analyzed the deletion method used (if any) and categorized the types of potentially-sensitive data found on the drives through inspecting what files are available upon plugging in the drive without any special tools, and by using forensic tools to recover any data deleted in an insecure manner.

We recognize that, regardless of software deletion methods, hardware forensics attacks may be performed on the thumb drive by removing the NAND flash chip and placing it in a reader [5] to gain access to data. This is not a common attack vector for the average person (and very specific to solid-state storage), so we do not consider it in our threat model. Thus, our threat model encompasses the whole of software attacks on an intact thumb drive. See Section 3.1 for information about hardware attacks.

The rest of the paper is structured as follows. Section 2 discusses related work. Section 3 gives background on thumb drive storage characteristics, deletion methods, and categories of sensitive data. Section 4 introduces our study methodology. Section 5 gives study results, special cases, limitations, and delimitations. Section 6 gives discussion and future work, and Section 7 concludes.

Maybe
do
Something
Similar

2 RELATED WORK

To the best of our knowledge, our study is the only study that measures drive owners' thoughts and beliefs about deletion and deletion effectiveness through human subjects research. Thus, the majority of our results section is novel and focuses on data gathered from the buyback participant survey in relation to secure deletion methods, beliefs, and effectiveness. However, other studies categorized data found and deletion method from storage devices purchased from secondary markets, and we summarize their contributions here.

Garfinkel and Shelat [12] acquired 158 hard drives on the secondary market between 2000–2002. Forensic tools were used to recover files, and the types of files were categorized. The authors found only 12% of their purchased drives were sanitized using a strong method that overwrites all hard drive sectors with zeros. They found most drives contained data of some kind, and 42 drives had possible credit card numbers.

In 2007, Valli and Woodward [45] investigated 84 hard drives originating from large corporations and found that 23 of the drives yielded significant exposure of sensitive data. A number of special interest cases are identified in which disks contained illicit, personal, and corporate-identifiable information.

Jones et al. [22] obtained 346 used disks spanning five countries over 5 years (2005–2009). The authors found a consistent improvement in the reduction of both commercial and personal data found over the study period, with the lowest level falling to 30% of drives containing individual data.

Jones et al. [23] also performed a study in which they purchased and analyzed 43 USB storage devices bought from auctions, fairs, and eBay. The study found that 95% of drives contained data that could easily be recovered, 4% of the drives had been effectively sanitized, and 49% of the readable drives had been deleted or formatted, but still contained recoverable data.

In 2011, Sansurooah and Szweczyk [37] acquired, forensically imaged, and analyzed 80 used USB storage devices from eBay Australia. They found 87% of drives did or contained attempts to delete data, and, out of those, 4% of drives were completely sanitized of all data. 95% of the drives contained recoverable data, and 13% of drives showed no evidence of any deletion attempts.

Table 1 illustrates key differences between each study. Note that data classifications are often ambiguous (e.g. what exactly constitutes personal data?) and cannot be directly compared across studies.

Table 1. Comparison of Related Work

Study	Storage device	Deletion methods identified	Data classifications	Human subjects study
[12]	Hard drives	Some ⁺	File types, CCNs, mail headers	No
[45]	Hard drives	Some ⁺	Personal, commercial, illicit	No
[22]	Hard drives	Some ⁺	Individual, commercial, illicit	No
[23]	Thumb drives ⁺	Some ⁺	Individual, commercial	No
[37]	Thumb drives ⁺	Some ⁺	Individual, commercial, file types	No
This study	Thumb drives	Full ^{**}	Personally-identifiable, corporate commercial, corporate confidential, illicit	Yes

⁺ Study uses term “USB Storage”, but thumb drives are inferred

^{*} Does not measure all possible deletion methods described in Section 3.2

^{**} Measures all possible deletion methods described in Section 3.2

3 THUMB DRIVES AND DELETION TECHNIQUES

Even though both are common storage devices, thumb drives are fundamentally different from hard drives. This section gives a brief background on thumb drives, discusses four deletion methods we categorized in our study, and introduces the categories of potentially-sensitive data we searched for on the drives.

3.1 USB Thumb Drive Background

The drives collected in our research were all USB thumb drives consisting of a USB connector, one or more NAND flash chips (typically in a TSOP48 package), and a microcontroller device to coordinate access to the NAND flash storage.

The NAND flash chip is a type of memory storage. In addition to reads and writes, it also accepts erase requests at the raw level. However, only the typical read/write hard drive interface is exported to the operating system.

NAND flash must implement specialized remapping and wear-leveling algorithms due to its physical characteristics: (1) In-place updates are generally not allowed—once a location is written, the location must be erased before it can be written again; (2) NAND reads and writes occur to smaller flash pages, but erasures are performed on larger flash blocks consisting of contiguous pages; thus, before a written page can be written again, the flash block containing this page must be erased, and other in-use pages in the same flash block need to be copied elsewhere; and (3) each storage location can be erased only 10K-1M times [8].

These physical challenges are commonly solved through the addition of a flash translation layer (FTL). The FTL sits atop the raw NAND flash interface, typically in the hardware. For backward compatibility, the FTL exports the hard drive interface that accepts only read and write requests; thus, the flash blocks cannot be erased directly¹. As a common optimization to mask slow writes and erases, when flash receives a request to overwrite a flash page, the FTL remaps the write to a pre-erased flash page, stamps the page with a version number, and marks the old page as invalid² to be cleaned later during the garbage collection cycle. These invalid pages are not accessible to components above the block layer, but can be recovered by forensic techniques [5]. To prolong the lifespan of the flash, wear-leveling techniques are often used to spread the number of erasures evenly across all storage locations.

We investigate data which may be retrieved through the microcontroller interface and high-level software forensics tools. In other words, the threat model for this research concerns an attacker using software tools only. Specialized hardware forensic attacks that look at the raw NAND flash chip [5] are beyond the scope of this work and are future work.

Most thumb drives come pre-installed with a variant of the FAT file system [28]. A small amount of drives were found to have an intact non-FAT file system. We removed these 5 drives from our analysis to use the same low-level file system investigation technique on all drives. Drives were also excluded if files were not in the English language (2 drives) or the drives did not work at all when plugged into a computer (6 drives). Analyzing drives formatted in other file systems or with files in non-English languages is future work. See Table 2. We also attempted to purchase drives of size 8GB or smaller to speed analysis of data on the drives.

Table 2. Breakdown of Drives Eliminated from the Study

	Buyback drives	Market drives
Initial total	140	120
Exclusion: non-FAT file system	4	1
Exclusion: non-English language	4	0
Exclusion: did not work	6	2
Final study totals	126	117

3.2 Deletion Methods

We focus our study on the deletion actions taken before the drive is sold or traded. Thus, if the drive shows evidence of past file deletions, but not all files have been deleted, we categorize the drive as not having been deleted. Similarly, we do not attempt to determine the amount of times in the past a drive has been formatted if it currently contains a live file system.

In order to determine the method used for deletion, binary images of flash memory were inspected using a popular binary file editor called hexedit [18]. We categorized the drives in the following ways:

¹ The TRIM command [39] is implemented to optimize performance and is not guaranteed to erase pages/blocks [24].

² Flash overwrites might be allowed for some special cases, such as marking a page invalid.

- **Not deleted (none):** The drive contains files readable by the operating system when plugged into a computer. Any computer user could see these files without any special tools.
- **Normal delete:** The drive does not contain readable files when plugged into a computer, but the drive shows evidence of deleted files that were deleted by 1) emptying a trash can, 2) selecting the file and pressing the “delete” key, or 3) using a command line delete or remove command standard to the operating system (such as Linux `rm` or Windows `del`). This type of deletion is evident in the binary image by observing that the first byte of a file or directory’s name in a directory entry has been changed to the special hex number ‘E5’. Files deleted using a normal delete may be recoverable using high-level software forensics tools.
- **Quick format:** The drive shows evidence of a quick format, which can be performed in Windows by using the `format` command with the `/q` flag or by right-clicking on the drive and selecting format with the “quick format” option checked. In Linux, a quick format can be performed with the `mkdosfs` command, and in Mac OSX by using the Disk Utility with the defaults enabled. A quick format can be identified by the absence (or zeroing) of the file allocation table, which is an indexing structure in the FAT file system. The user has performed a quick format if the file allocation table is zeroed but old entries exist in the FAT file system data section. Files deleted using a quick format may be recoverable with high-level software forensic tools.
- **Full format:** A full format had occurred when the FAT file system data and file allocation tables have been overwritten by zeros, and a clean FAT file system is present. A full format may be performed in Windows by using the `format` command without the `/q` flag or by right-clicking on the drive and selecting format with the “quick format” option unchecked. Files deleted using full format are not recoverable with high-level software forensics tools.
- **Other:** Methods that did not fall into the previously discussed categories were classified as other. This category includes methods such as overwriting the drive with random characters or overwriting with single/alternating characters³. No readable file system is present. Files deleted using other methods are not recoverable with high-level software forensics tools.

3.3 Categories of Data

Files on each thumb drive were classified according to four types of potentially-sensitive data. We expand the definitions of Valli and Woodward [45] to include four categories discussed below:

- **Personally Identifiable Information (PII):** We used the standard set by the National Institute of Standards and Technology [27], which includes full names, addresses, SSNs, IDs, credit card numbers, and faces.
- **Corporate Commercial (CComm):** Any piece of information about a company or organization that could, but not

necessarily, be made publicly available, such as advertising, product manuals, and product specifications.

- **Corporate Confidential (CConf):** Any piece of information that originated from a company or organization that which the company or organization would not want publicly available or could be illegal to release. This includes lists of customers/employees that contained PII, trade secrets, and/or sales/marketing plans.
- **Illicit:** Anything that is pornographic or illegal in nature. By illegal in nature, we mean data that could serve as evidence of potential crimes.

On occasion some pieces of data found fell into two or more categories. We counted these cases in every category applicable.

It was beyond the scope of the research to determine if music, movies, and TV shows were downloaded legally or illegally; thus, we did not include those file types in our potentially-sensitive categorizations. More discussion on this topic can be found in Section 6.

4 METHODOLOGY

This section is partitioned into three subsections. The first subsection gives background on how the market drives were obtained. The second subsection discusses the content of the survey presented to participants in the thumb drive buyback program, and the third subsection gives details on the procedures used in processing and categorizing all thumb drives.

4.1 Market Drives

We purchased 87 used thumb drives from eBay and 33 used thumb drives from Amazon. In both market purchases, our primary differentiating factor was cost (cheapness) and small size of drive (mostly under 8GB).

The eBay thumb drives were purchased between May and June in mostly small lots of 1–2 drives per purchase. Three purchases were made in lot sizes of 8–10, but the lots showed extreme diversity in thumb drive brands and sizes.

The Amazon thumb drives were purchased between March and May of the same year. The majority of thumb drives were single purchases from multiple sellers, with the largest lot group from a single seller being of size three. Again, each lot purchase showed diversity in branding and size.

4.2 Buyback Survey

We recruited participants for the buyback study through flyer distribution on a university campus and a single campus-wide email advertisement to university students and employees. The study was conducted inside a large Midwestern university and was open to participants in and outside the university aged 18 or over. Flyers were posted in main buildings throughout the university campus, and table tents were posted in the main student union building for

³ Encrypted devices may appear random [42] and therefore indistinguishable from a random overwrite. Thus, we are not able to definitively tell if these devices are encrypted or randomly overwritten. Either way, no data is recovered.

three days. Each advertisement was approved by our institutional review board.

No directly personal identifiable data was collected or used as an identifier. Instead, an alphanumeric identifier was assigned to all collected thumb drives and surveys. Any incidental data found on thumb drives that could possibly identify a participant was kept on a restricted university data server accessible only from researcher computers connected via IPsec, and the thumb drives themselves were kept in a locked university room. After expiration of the IRB, all thumb drive data images will be securely deleted, and all participant thumb drives will be physically destroyed. All researchers and survey administrators have completed a CITI class for training in human subjects research prior to starting this research [7]. In addition, no deception was used in our advertising or recruitment materials. Our survey consent form states: "This study involves research in order to determine user habits and expectations of data deletion as well as if data remains on USB drives despite user efforts to remove data."

Our procedure for conducting the survey is outlined below:

1. Study participant arrives and expresses interest in the study.
2. Survey administrator provides the consent form and asks the study participant to read it and place a check mark at the bottom of the form if they consent. (Neither names nor initials of participants were collected to protect the anonymity of the participants).
3. Survey administrator asks for the participant thumb drive and places it in a bag labeled with a unique alphanumeric identifier.
4. Survey administrator writes the same unique alphanumeric identifier on top of the survey (see Appendix), and the survey is given to the study participant.
5. The study participant is advised that he/she may answer any or all of the questions. Also, if the study participant no longer wants to participate in the study, their original thumb drive is returned. (Note: No participants withdrew from the study.)
6. The study participant returns the completed survey to the survey administrator. The survey administrator then gives a brand new, in-package thumb drive to the study participant.

All buyback survey administrators were instructed to answer questions, with exceptions related to questions concerning:

- If the participant needs to erase his or her drive.
- How the participant should erase his or her drive.

This was done to best simulate the actions taken by users that sell or trade their used thumb drives through other means (such as eBay or Amazon).

We recognize this study is not a perfect mirror of users selling or trading used thumb drives through the market, as participants may be more inclined to trust a university-sanctioned study.

Market drives, while not under IRB, were processed and treated with the same security procedures as the IRB-protected devices.

4.3 Drive Analysis Process

All drives obtained from the buyback and the market groups were processed in the same way, and the buyback survey identifiers are tied to individual drives.

The basic drive analysis phase can be broken down into five steps:

1. Record metadata identifying the drive,
2. Create safe and working images for analysis,
3. Classify deletion technique,
4. Classify non-deleted data, and
5. Classify data found with forensics tools.

Each phase is detailed in the following subsections. After each phase, resulting data found was recorded to a database containing results with no personal identifiers. The analysis was performed on Linux Debian 7 workstations.

Step 1) Identify drive metadata: The basic characteristics, such as manufacturer, model, identifying marks, and size of the flash drives were identified using the Linux commands `'fdisk -l'` and `'lsusb'`. To assist with cataloging, a photo of each USB flash drive was taken. The information, along with the drive's unique alphanumeric identifier, was entered into a wiki and database for tracking. *Similar format?*

Step 2) Create safe and working drive images: Two unmodified binary level copies of the drive were taken: a safe copy to be stored in a separate location and a working copy. The safe copy exists to preserve the state of the drive as we received it and was created using the Linux `dd` command. We then copied the safe copy image into a working copy image for which all future forensics analysis steps was applied.

Step 3) Classify deletion techniques: We mount the image as a type `'vfat'` file system and search for any visible files and directories. If any files or directories were available, we classified the drive as *not deleted* (see Section 3.2) and skip to the next step (classify non-deleted data).

However, if no files or directories are visible, the user has likely deployed some sort of deletion technique. We then use the method described in Section 3.2 to classify the deletion method as a *normal deletion*, *quick format*, *full format*, or *other*.

Through manual analysis of the raw image through the editor `hexedit`, we were able to classify the following deletion techniques used (if any): *normal (or regular) deletion*, *quick format deletion*, *full format deletion*, or *other deletion* methods. We then move to the step 5, classifying data found with forensics tools.

Step 4) Classify non-deleted data: The working copy image of each flash drive was mounted and examined for files visible without the use of any forensics tools. Directories were explored both via command line to uncover possible hidden files as well as through a GUI. Files found using normal file browsing methods were grouped into the four different potentially-sensitive categories defined in Section 3.3. Files were then separated into four category-specific directories. When a file qualified for multiple categories, copies of the file were added to additional category

directories. The number of bytes found in each category were measured with the Linux command `'du -b -apparent-size'` on a Debian 7 Linux system to get an exact byte count.

Step 5) Classify data found with forensics tools: Each flash drive working image was then analyzed using an open-source forensics tool suite [33, 44]. The files returned were then classified and sorted into the same groups discussed in Step 4. It is important to note that non-deleted files are also “recovered” using the forensic tools, so files discovered in Step 4 are once again counted in this step.

5 RESULTS

This section is broken into three subsections. Subsection 5.1 discusses specific examples of sensitive data we were able to recover. Subsection 5.2 compares measurable attributes between the market and buyback drives groups to determine if the buyback participants are representative of market sellers. Finally, subsection 5.3 analyzes buyback participants’ thoughts and beliefs concerning deletion compared to their actual deletion methods across age, gender, and profession/field of study.

For statistical purposes in subsections 5.2 and 5.3, the four drives that were deleted using techniques described as ‘other’ were included in the group ‘full format.’ We did this because the end result was much the same—a drive with no recoverable data using our techniques. Specifically, one drive was found overwritten with an alternating bit pattern, and three drives were either encrypted or randomly overwrote.

Since the buyback drives had a survey component, we were also able to correlate the participants’ initial surrender mode found on the devices with the description of the deletion technique by using survey question 3a (see Appendix). Survey question 3a is useful because it asks participants to describe the method they used to delete data. We identified one buyback drive that performed per-file secure deletion. We also identified two additional buyback drives that employed multiple sanitization practices. Our findings are shown in Table 3. Since the market drives did not come with such a survey, we were unable to come to similar conclusions concerning the market drives. We also did not exclude these drives from our study.

We used the Pearson’s Chi-squared analysis to analyze the relationships among the categorical data. We consistently use $\alpha = 0.05$ as our significance level for statistical analysis.

Table 3. Buyback Drives from which Participants Indicated Complex/Non-Categorized Surrender Behavior

ID	Categorized surrender mode	Survey 3a answer
B044	None	<i>“used a program called erasure which I downloaded from the internet”</i>
B113	Quick Format	<i>“one zero pass on empty space then regular formatting, no need to worry I use DMGs encrypted in 256 bit AES”</i>
B117	Quick Format	<i>“single pass writing zeros to it then erase”</i>

5.1 Buyback and Market Drives Examples

The buyback drive marked with identifier B092 (2GB Sandisk drive) had a large variety of sensitive information crossing multiple categories identifying the study participant and the participant’s business. The drive included the participant’s picture, resume, employment history, family addresses and contact information, a 2011 tax return, medical screening information, a color copy of the participant’s passport, military discharge paperwork, a W-4 2012 form, direct deposit information, a copy of a voided check, and lists of names, addresses, phone numbers, and birthdays of employees. The drive also contained commercially produced and homemade pornographic videos. The survey connected to this drive indicated the participant deleted information via the normal deletion method, is ambivalent about deletion (selected “in between” on survey question 5), and thought recoverability of the data would be somewhat easy.

The buyback drive marked with identifier B096 (4GB Sandisk drive) had a recoverable passport. This participant did not delete the thumb drive, yet answered that he or she “always care(s)” about deletion. When asked on the survey why the participant did not delete, the participant responded “in case I needed it for future purposes.” This example may be illustrative of the implicit trust of a university study; however, the study description was clear in that the participant’s drive would be traded (not given back) and then associated data made anonymous.

The buyback drive marked with identifier B002 (16GB PNY drive) contained a resume, one text file with a Bitcoin wallet private key, and Litecoin wallet encryption and private key. The participant used quick format as a deletion method, “often cares” about deletion, and thought recoverability of the data would be “somewhat easy”. When asked about deletion method used, the participant said “I just transferred my flash drive data onto my personal computer.” This answer implies the participant did not understand what was meant by the term *deletion*.

The market drive marked with identifier M081 (1GB Apacer drive) contained sensitive information about the internal workings of a middle school. The drive contained middle school teachers’ pictures, students’ pictures, and names of administrators, teachers, and students. It also contained school schedules, plans, announcements, and internal incident report documents. This drive was deleted using a quick format.

The market drive marked with identifier M055 (8GB Sandisk drive) contained on mount a company payroll spreadsheet with personally-identifiable information for multiple employees of the company. The drive also contained invoice information for the company, as well as personal photographs and other papers with individual names that were not related to the company. The drive was deleted using normal deletion.

The market drive marked with identifier M086 (2GB Sandisk drive) contained internal documents for a major clothing retailer in the United States. The drive also contained an individual’s tax document with the person’s name, address, and social security number. Also present on the drive were personal photos with names and addresses of presumable acquaintances of the previous owner. The drive was deleted using normal deletion.

The market drive marked with identifier M115 (2GB Lexar drive) contained a communication from a state office to a university in that state requesting funding and recognition for a program, as well as several corporate commercial documents pertaining to that university. The drive also contained personal information from an executive-level member of the university—including tax documents, personal photos, and an illicit photo. The drive was deleted using normal deletion.

5.2 Comparisons between Drive Groups

Overall, we found that the drives purchased from the marketplaces were not different from the buyback drives in terms of presence of potentially-sensitive data nor methods of deletion. This leads us to reason that the buyback drives would be similar to the market drives in other ways that were impractical to discern from the market drives (i.e. the confidence sellers had in their deletion techniques or the demographic information of the sellers). We found no statistically significant patterns to discern relationships among deletion practices.

First, we compared the market drives to the buyback drives in terms of method of deletion (see Figure 1) and presence of potentially-sensitive data (see Figure 3). Using chi-squared goodness-of-fit analysis, we found the drives not dissimilar to the buyback drives; $\chi^2(3, N = 243) = 1.53, p = 0.33$. (As a reminder, we cannot prove similarity of the drive groups, only that the drive groups are not dissimilar.) Of interest, over 33% of drives did not have any attempt to remove data upon surrender.

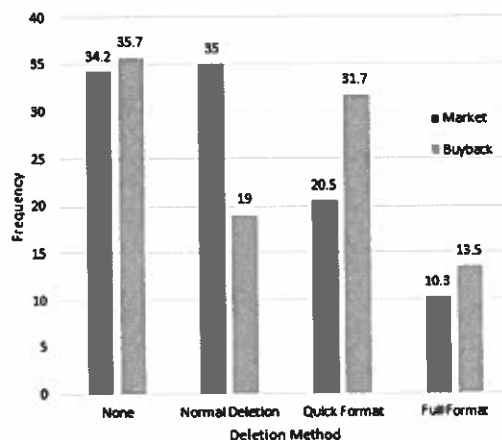


Figure 1. Deletion method by group between buyback and market drives as percentages.

By re-categorizing the deletion methods into methods that yield recoverable data (insecure) versus methods that do not (secure), we can further see the similarities between drive groups. See Figure 2.

Also, we found no statistically significant differences when we compared the market drives to the buyback drives in terms of the presence of potentially-sensitive data. $\chi^2(4, N = 243) = 1.82, p = 0.23$ (see Figure 3).

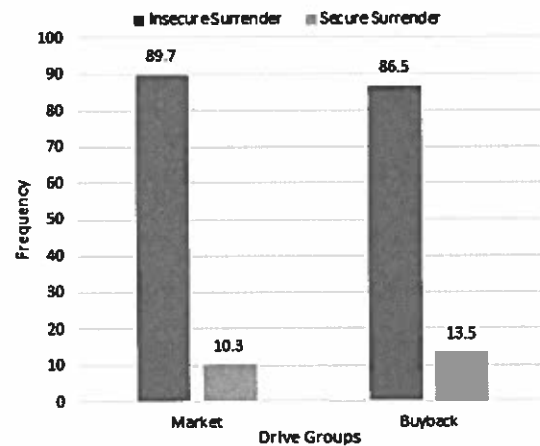


Figure 2. Deletion effectiveness by group as percentages.

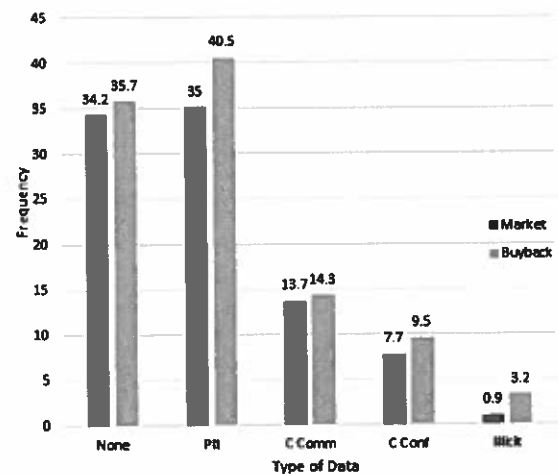


Figure 3. Sensitive data present on market and buyback drives as percentages.

The percentage of potentially-sensitive data found in the market drive group was 65.81%, and the percentage of potentially-sensitive data found in the buyback drive group was 64.29%. In total, 65.02% of data found in both groups was classified as potentially sensitive. The spread of potentially-sensitive data per device was also not statistically different across drives not included in the full format group. $\chi^2(3, N = 185) = 0.06, p = 0.80$ (see Table 4).

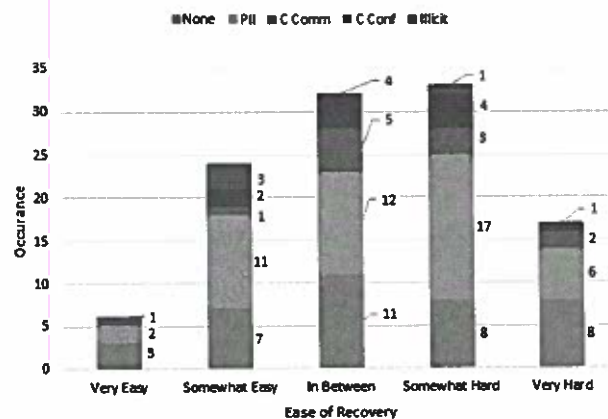
Because of these results, the drive populations may be not dissimilar in other characteristic ways, such as in perceptions of deletion. This means the survey data may be predictive of the general patterns in people surrendering drives.

Table 4. Percentage of Drives by Category with Potentially-Sensitive Data Recovered

	Market drives	Buyback drives
Potentially-sensitive data recovered	67.1%	68.8%
No potentially-sensitive data recovered	32.9%	31.2%

5.3 Buyback Results

We analyzed the drives to compare the presence of potentially-sensitive data with the confidence the participants had in the deletion methods used to clean the drives before surrender. In that, we found no statistically significant relationship between these two variables. $\chi^2(4, N=90) = 3.17, p = 0.47$. See Figure 4. Please note that 36 participants did not indicate they removed data—thus, they were removed from this analysis.

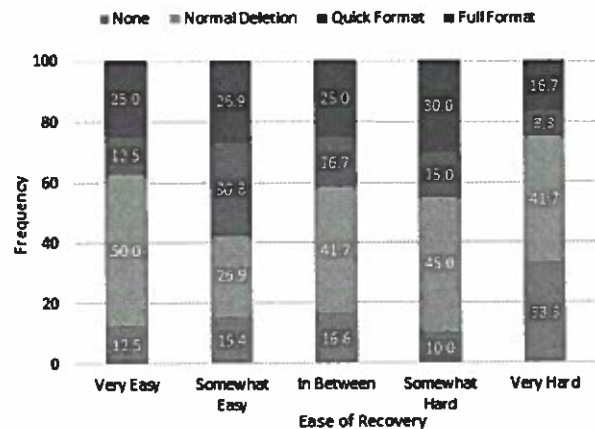
**Figure 4. Presence of sensitive data by perception of data recoverability.**

This leads us to conclude that there is no statistically significant relationship between the presence of sensitive data on the drive and the confidence the participant had in removing information from the surrendered drive.

We also tested to determine if there was a statistically significant relationship between the variables of ‘deletion methods’ and ‘confidence of deletion’ (see Figure 5).

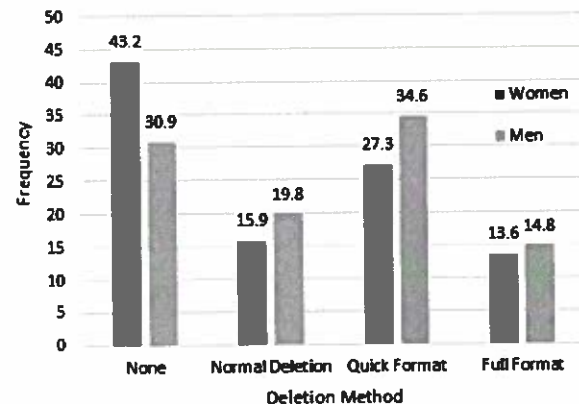
We removed from consideration those who either responded ‘did not know’ or failed to respond to the question regarding confidence of deletion. As with the other categories, we found no statistically significant relationship ($\chi^2(12, N=90) = 7.94, p = 0.21$). In fact, we see a disturbing uniformity between deletion methods present in all confidence categories (see Figure 5). For instance, we see that 83.3% of those selecting “Very Hard” used methods in which data was recoverable, while in “Very Easy,” we found 12.5% of users who did use deletion methods in which data could not be recovered.

5.3.1 Gender. We had $n=1$ participant who declined to include their gender, and thus was removed from the proceeding analyses. Of the remaining participants, 44 were female and 81 were male.

**Figure 5. Deletion method compared to confidence of deletion as a percentage.**

We found no statistically significant differences between genders with respect to deletion method ($\chi^2(3, N=125) = 1.37, p = 0.29$), presence of sensitive data ($\chi^2(1, N=125) = 0.93, p = 0.24$), nor confidence of deletion ($\chi^2(4, N=90) = 2.20, p = 0.30$). The percentage sums of potentially-sensitive may add up to over 100%, as some data may be counted in more than one category.

There is a slight preference for women to not delete the drive (see Figure 6); however, these values are within the error of the test. Notably, the percentage of men and women that chose the ‘full format’ (which yields no data) is similar.

**Figure 6. Deletion method by gender as percentages.**

We can then re-categorize the deletion methods shown in Figure 6 into insecure surrender and secure surrender methods, similar to what was defined in Figure 2. Surprisingly, we find similar percentages of men and women surrendered drives both securely and insecurely. Further, both men and women tend to use insecure methods. See Figure 7.

Similarly, we see slight trends for women to have PII contained on their drives (see Figure 8), but these are not statistically